

AI Auditor

1. The Independent Verification Layer: Why AI Auditing Is Different

Every governance policy, technical control, and security architecture discussed in this course depends on one critical capability: independent verification that those controls and processes are actually working as intended. That is the AI Auditor's role. Unlike the other roles in this section — which design, build, or operate AI systems — the AI Auditor evaluates them. The AI Auditor provides independent assurance that governance is not performative, that security controls are correctly implemented, and that AI systems behave consistently with their approved specifications.

In regulated industries, AI auditing is rapidly becoming a mandatory function — not a discretionary internal practice. The EU AI Act (2024) requires independent conformity assessment for high-risk AI applications. ISO/IEC 42001:2023 requires internal audit as part of the AI management system. GDPR Article 35 requires Data Protection Impact Assessments for AI systems processing personal data at scale. AI Auditors are the practitioners who conduct these assessments and produce the evidence that regulators require.

What distinguishes AI auditing from traditional IT auditing is scope and technical competency. AI Auditors must evaluate not just process compliance — did the organization follow its procedures? — but also technical system behavior: does the deployed model meet the performance, fairness, and robustness thresholds in its approved documentation? This technical dimension requires competency that pure documentation review does not demand.

2. Internal vs. External AI Auditing

Dimension	Internal AI Audit	External AI Audit
Conducted by	Organization's own audit function — employees or contractors reporting internally	Independent third parties — accounting firms, specialized AI audit firms, regulatory examiners, EU notified bodies
Primary purpose	Assurance to management that controls are operating; identification of improvement opportunities	Assurance to regulators, investors, and external stakeholders that the organization's claims about AI systems are accurate
Scope authority	Defined by internal audit charter; typically broad but bounded by internal politics	Defined by regulatory requirement or engagement terms; regulatory examiners have statutory access authority
Output	Internal audit report; management letter; findings and recommendations	Audit opinion; conformity assessment certificate; regulatory examination report
EU AI Act requirement	Required as part of ISO/IEC 42001 management system; supports	Required for high-risk AI applications under EU AI Act conformity assessment — by

	external audit readiness	notified bodies in some cases
--	--------------------------	-------------------------------

Internal and external auditing are complementary, not alternatives. Organizations without mature internal audit programs rarely produce the documentation quality that external audits require. The internal audit function prepares the organization for external scrutiny — identifying documentation gaps, control weaknesses, and process failures before an external auditor or regulator finds them.

3. What AI Auditors Evaluate: Six Audit Dimensions

- **Documentation completeness:** Are model cards, data cards, system specifications, and conformity assessment documentation present, current, and accurate? Incomplete or outdated documentation is itself an audit finding, even if the underlying practice is compliant.
- **Process compliance:** Did the organization follow its own AI governance procedures? Were required approvals obtained? Were governance gates enforced? Were fairness evaluations conducted at the required points in the development lifecycle?
- **Control effectiveness:** Are the technical controls that governance policy requires — deployment gates, fairness monitoring, audit logging — actually implemented and operating as designed? Documented controls that exist only on paper are a critical audit finding.
- **Model performance against specifications:** Does the deployed model meet the accuracy, fairness, and reliability thresholds documented in its governance artifacts? Performance below documented thresholds that has not been detected and escalated indicates monitoring failures.
- **Audit trail completeness:** Are governance events logged in a way that allows retrospective verification? Can the auditor reconstruct the history of model approvals, version promotions, and governance reviews from available evidence?
- **Regulatory compliance:** Does the AI system's design and operation satisfy applicable regulatory requirements — EU AI Act conformity assessment, GDPR DPIA requirements, sectoral AI regulations? This is the dimension with the most direct external accountability.

4. Categories of Audit Evidence

Evidence Category	Examples	Primary Sources
Technical evidence	Model version records; training pipeline audit logs; deployment records; monitoring dashboards showing production performance over time	Model registry; CI/CD pipeline logs; MLOps monitoring platform; cloud provider audit logs
Process evidence	Approval records for model deployments; governance review documentation; fairness evaluation reports; risk assessment documentation with sign-offs	Workflow management systems; governance platforms; email/document repository with timestamps
Regulatory evidence	Data Protection Impact Assessments (DPIAs); EU AI Act conformity assessment documentation; evidence of human oversight mechanisms; post-	Privacy office; legal/compliance function; EU AI Act registration database

	market monitoring reports	
Performance evidence	Fairness metric evaluation results at deployment; post-deployment monitoring results; adversarial robustness test results	MLOps platforms; evaluation run records; model card documentation with metric values

The adequacy of audit evidence is itself an audit judgment. An auditor who accepts a model card as evidence that fairness was evaluated must verify that the card reflects an actual evaluation — not a placeholder or a copied template. Verification requires cross-referencing the card against evaluation run records in the MLOps platform. Evidence that cannot be corroborated by independent sources is weaker evidence.

5. Model Performance Auditing: The Technical Dimension

Model performance auditing is the dimension that most distinguishes AI auditing from traditional IT auditing. AI Auditors test that deployed models perform as documented — not just that documentation exists. This technical testing requires competency beyond standard audit methodology:

- Accuracy evaluation: Running model evaluation on held-out test sets to verify that production model performance meets documented thresholds. A discrepancy between documented and measured accuracy indicates either documentation error or model drift since deployment.
- Fairness metric evaluation: Testing fairness metrics (demographic parity, equalized odds, calibration) across protected group cohorts against the thresholds specified in the model's governance documentation. Below-threshold performance not previously detected indicates monitoring gaps.
- Performance degradation assessment: Comparing current evaluation results to those documented at deployment. Significant degradation without corresponding alerts indicates model drift monitoring failures.
- Adversarial robustness testing: If adversarial robustness requirements are documented, testing model behavior on adversarial inputs to verify that robustness meets specifications. This requires AI Auditors to understand and apply adversarial ML test methodologies.

Organizations recruiting AI Auditors must look for this technical competency alongside traditional audit skills. An AI Auditor who can review documentation but cannot run evaluation scripts and interpret metric outputs cannot provide complete assurance on model performance — a significant gap given that model performance compliance is an EU AI Act requirement for high-risk applications.

6. Privacy Auditing: Membership Inference and Prompt Extraction

AI Auditors with privacy responsibilities conduct technical privacy audits of AI systems trained on sensitive data. The key privacy risks AI Auditors test for are data memorization and unintended disclosure:

- Membership inference testing: Using published membership inference attack tools to determine whether specific records can be identified as training data members. A positive membership inference result indicates the model has memorized training data to a degree that creates re-

identification risk — a GDPR Article 25 (data minimization) and Article 32 (appropriate security) compliance issue.

- Prompt extraction in LLMs: Testing whether LLM systems will reveal information from their training data or system prompt when manipulated through prompt injection and jailbreaking techniques. Models that can be induced to reproduce training data samples or reveal system prompt contents create privacy exposure.
- Differential privacy verification: Verifying that privacy budgets were correctly calculated and that noise parameters match documented privacy guarantees. This requires mathematical review of the privacy budget accounting, not just documentation review.
- Data retention compliance: Verifying that training data was retained only as long as permitted under applicable data governance policies and regulations — and that models trained on data that should have been deleted do not retain that data's information through memorization.

7. Named Incident: Audit Log Manipulation (2024)

Security Research — AI Platform Audit Log Attacks (2024): Security researchers demonstrated in 2024 that audit log systems for AI platforms can be targeted to suppress evidence of policy violations. The attack pattern: an attacker with access to the logging infrastructure modifies log entries or suppresses specific event types, preventing auditors from reconstructing the history of model deployments and governance decisions. More subtle attacks target the monitoring system that generates audit-relevant alerts — tuning it to ignore specific anomaly patterns that would trigger governance review. AI Auditors counter this with tamper-evident audit logging: immutable logs stored in systems operational teams cannot modify, implemented through append-only storage, cryptographic log chaining, or out-of-band log shipping to a dedicated audit log store. Systems designed for auditability make log manipulation attacks detectable rather than invisible.

8. Red Team Perspective: Stress Testing Audit Processes

Red teams simulating AI audit evasion look for patterns that distinguish genuine compliance from compliance theater — systems that appear compliant to a documentation review but fail when subjected to technical verification or process walkthrough:

- Gaps between documented processes and actual organizational behavior: Governance processes described in policy that nobody follows in practice. Process walkthroughs — observing actual operations, not just reviewing documentation — find these gaps that document-only reviews miss.
- Backdated or fabricated documentation: Documentation that appears complete but was created after the fact to satisfy audit requirements rather than as a contemporaneous record of governance activities. Metadata analysis and corroboration with independent sources detects this.
- Monitoring configurations altered before audit: Fairness monitoring or anomaly detection thresholds changed before audit review to suppress alerts that would trigger governance review. Audit log review of monitoring system configuration changes detects this pattern.
- Model registry mismatches: Registry records that do not match deployed model artifacts — the registry shows a compliant model version while a different version is actually serving inference requests.

- Organizational scale failures: Governance processes defined when the AI portfolio was small that broke down as AI deployment scaled. The process worked for five models; it does not scale to fifty models without process automation.

9. Regulatory Compliance Auditing: EU AI Act and ISO 42001

Framework	Key Audit Verification Points	Evidence Required
EU AI Act (2024) — High-Risk	AI system registered in EU database; conformity assessment complete; human oversight mechanisms implemented; quality management system (Article 17); post-market monitoring (Article 72)	Registration confirmation; conformity assessment documentation; system specification showing human oversight; QMS documentation; monitoring reports
ISO/IEC 42001:2023	AI Management System documented; internal audits conducted; management reviews completed; continual improvement evidence; nonconformity tracking	AIMS policy and procedure documentation; internal audit records; management review minutes; corrective action records
GDPR Article 35	DPIA conducted for AI systems with high privacy risk; DPIA documented risks and mitigations; Data Protection Authority consulted where required	DPIA documentation; consultation records; evidence of mitigations implemented

Organizations subject to both EU AI Act and ISO/IEC 42001 face compounding audit requirements. Experienced AI Auditors design audit programs that satisfy multiple frameworks in a single audit cycle — using evidence collected for one framework to satisfy another where requirements overlap — rather than conducting separate audits for each framework.

10. AI Auditor Independence: The Non-Negotiable Requirement

The AI Auditor's effectiveness depends entirely on independence. An audit function without genuine independence cannot provide credible assurance — it provides opinions that reflect the interests of those who control the auditor's access, scope, and reporting.

- Structural independence: The AI Auditor must not report to the same organizational function that operates the AI systems being audited. Internal AI audit typically reports to the Audit Committee or Board — not to the CTO, CISO, or business unit leadership.
- Access authority: AI Auditors must have documented authority to access all systems, documentation, and personnel relevant to their audit scope. Access restrictions imposed by operational teams are audit findings, not acceptable scope limitations.
- Unfiltered reporting: Audit findings must reach governance stakeholders — Board, Audit Committee, Regulators — unfiltered. Operational management review of audit reports before they reach governance stakeholders compromises independence.
- Scope protection: An AI Auditor told to exclude specific systems from scope, delay reports, or moderate findings must escalate to the audit committee or equivalent governance body. Compliance

with scope restrictions that serve operational management's interests rather than governance stakeholders' interests compromises independence.

Memory Anchor — Financial Auditor: An AI Auditor functions like a financial auditor: they provide independent assurance to stakeholders who cannot directly verify the claims being made. A financial auditor who reports to the CFO and allows the CFO to modify audit findings before they reach the Board is not an independent auditor — they are an organizational instrument. The same logic applies to AI auditing. Independence is structural, not attitudinal.

11. Closing the Governance Loop

AI Auditors complete the AI governance cycle. Policies are defined (AI Governance Engineer), risks are identified (AI Risk Analyst), controls are implemented (Governance Engineer, Security Architect), operations produce evidence, and auditors independently verify that the evidence reflects genuine compliance. Without the auditor function, governance is self-reported — organizations that know they are non-compliant can avoid documenting it. The AI Auditor makes accountability real rather than theoretical.

In the NIST AI RMF 1.0 cycle, audit closes the loop between MANAGE (implementing risk treatment) and MAP (reassessing risks). Audit findings that identify control failures or documentation gaps feed directly back into the risk identification process — prompting updated risk assessments and revised control implementations. Organizations that treat audit as a one-time event rather than a continuous feedback mechanism fail to capture this dynamic and allow compliance gaps to accumulate between audit cycles.

Key Terms Glossary

Term	Definition
Internal AI Audit	Audit conducted by the organization's own audit function — providing management assurance and identifying improvement opportunities
External AI Audit	Audit conducted by independent third parties — providing regulatory and stakeholder assurance; required by EU AI Act for certain high-risk AI applications
Conformity Assessment	EU AI Act formal process of verifying a high-risk AI system meets regulatory requirements before deployment; may require notified body review
Notified Body	EU AI Act independent assessment body formally designated by an EU member state to conduct conformity assessments for high-risk AI applications
Membership Inference Attack	Privacy attack testing whether specific records can be identified as training data members — positive results indicate data memorization creating re-identification risk
Prompt Extraction	LLM privacy test using prompt injection to determine whether the model reveals system prompt contents or reproduces training data — relevant to GDPR compliance

Tamper-Evident Logging	Audit log implementation that makes log modification detectable — using append-only storage, cryptographic chaining, or out-of-band log shipping
Data Protection Impact Assessment (DPIA)	GDPR Article 35 requirement for high-privacy-risk AI systems — documents risks, mitigations, and (where required) Data Protection Authority consultation
Audit Independence	Structural requirement that AI Auditors report to governance stakeholders (Board, Audit Committee) rather than to the operational functions they audit
ISO/IEC 42001:2023	International certifiable AI Management System standard requiring internal audit, management review, and continual improvement as core system elements
Audit Trail	Immutable chronological record of governance events enabling retrospective verification of compliance — a key evidence category for AI Auditors
Process Walkthrough	Audit technique of observing actual operations rather than reviewing documentation — detects gaps between documented and actual governance processes

Quick Revision Checklist

- AI Auditors provide independent verification that governance controls are actually working — not self-reported compliance.
- Internal audit: assurance to management; external audit: assurance to regulators and stakeholders — both required under EU AI Act and ISO 42001.
- Six audit dimensions: documentation completeness, process compliance, control effectiveness, model performance, audit trail, regulatory compliance.
- Four evidence categories: technical, process, regulatory, and performance evidence — adequacy of evidence is itself an audit judgment.
- Technical competency required: AI Auditors run evaluation scripts, interpret fairness metrics, conduct membership inference tests — not just document review.
- Privacy auditing: membership inference testing, prompt extraction testing, differential privacy budget verification.
- Tamper-evident logging counters audit log manipulation attacks — append-only, cryptographic chaining, or out-of-band shipping.
- EU AI Act audit requirements: EU database registration, conformity assessment, human oversight implementation, QMS (Article 17), post-market monitoring (Article 72).
- ISO/IEC 42001 audit requirements: AIMS documentation, internal audits, management reviews, corrective action records.
- AI Auditor independence is structural — must report to audit committee or board, not to operational management.
- Audit closes the NIST AI RMF loop: MANAGE (control implementation) → Audit (verification) → MAP (updated risk assessment).

10 Exam-Based MCQs — AI Auditor

These questions are written in SecAI+ exam style. Read every explanation, including for questions you answered correctly.

Q1. Scenario: An AI Auditor at a bank is reviewing compliance with the organization's governance policy, which requires fairness evaluation for all credit scoring models. Model cards for four production models document fairness metric values. When the auditor attempts to cross-reference these values against evaluation run records in the MLOps platform, no corresponding records can be found. An AI Auditor reviewing a financial services firm's AI governance program finds that model cards exist for all production models but cannot corroborate the fairness metric values in the cards against any evaluation run records in the MLOps platform. What is the MOST appropriate audit finding?

- A) The model cards are complete and satisfy documentation requirements — no finding is warranted
- B) The fairness metric values should be accepted as documented since the cards bear authorized signatures
- C) The absence of corroborating evaluation records is a significant finding — documentation cannot be verified as accurate
- D) The auditor should request that the data science team reproduce the evaluations during the audit

Answer: C **Explanation:** C is correct because audit evidence adequacy requires that documentation be corroborated by independent sources — model cards that cannot be traced to evaluation run records may be accurate, but an auditor cannot provide assurance on unverifiable documentation. This is itself a significant finding: the organization's audit trail is incomplete. A is wrong because the existence of signed documents does not constitute sufficient audit evidence if those documents cannot be corroborated. B is wrong because authorized signatures establish accountability for the document's content but do not verify its accuracy — the audit finding is that accuracy cannot be independently confirmed. D is wrong because asking the team to reproduce evaluations during the audit creates a sample of current performance, not evidence that the documented evaluations were conducted at the time of deployment.

Q2. Scenario: A regulatory examiner asks an AI Auditor to demonstrate that a deployed credit scoring model was approved through the organization's governance process before deployment. The examiner wants evidence that can be independently verified, not a self-attestation. Which audit evidence would BEST allow an AI Auditor to retrospectively verify that a model was deployed through the approved governance process six months ago?

- A) The current version of the model's model card
- B) Immutable audit logs from the CI/CD pipeline and model registry showing deployment approvals with timestamps and approver identities
- C) A signed attestation from the model's business owner confirming the governance process was followed
- D) The model's current fairness evaluation results

Answer: B **Explanation:** B is correct because immutable audit logs from the CI/CD pipeline and model

registry capture the deployment event contemporaneously — with timestamps, approver identities, and version information — providing retrospective evidence of what happened and who authorized it. A is wrong because the current model card may have been updated after deployment and does not provide retrospective evidence of the governance process followed at deployment time. C is wrong because a retrospective attestation is the weakest form of evidence — it is self-reporting by the party whose compliance is being assessed. D is wrong because current fairness evaluation results reflect the model's current state, not the governance process followed six months ago.

Q3. Scenario: During an audit of an AI system's monitoring controls, the AI Auditor reviews the audit log of monitoring system configuration changes. The log shows that fairness monitoring alert thresholds were lowered in sensitivity two days before the audit review commenced, resulting in 40% fewer governance review triggers over the preceding week. An AI Auditor discovers that the fairness monitoring alert thresholds for a high-risk AI system were changed two days before the scheduled audit review. The change reduced the sensitivity of alerts, causing fewer governance review triggers. What is this pattern MOST consistent with?

- A) Normal threshold tuning based on operational experience with the monitoring system
- B) Audit evasion through monitoring configuration manipulation — an audit finding requiring escalation
- C) A technical improvement to reduce false positive alert fatigue
- D) Standard pre-audit preparation to ensure monitoring systems are functioning correctly

Answer: B Explanation: B is correct because threshold changes immediately before audit review that reduce monitoring sensitivity are a red team-identified pattern of audit evasion — deliberately reducing the evidence of policy violations that audit would detect. The timing and direction of the change (reduced sensitivity, fewer triggers) is the key indicator. A is wrong because normal threshold tuning is typically documented through a change management process with business justification — the timing immediately before audit review and the direction of change (less sensitive) distinguish this from routine tuning. C is wrong because reducing false positive alert fatigue would be a legitimate reason for threshold adjustment in principle, but the timing before audit review makes this explanation require corroboration, not acceptance at face value. D is wrong because pre-audit preparation would involve testing that monitoring is working correctly, not changing thresholds to reduce sensitivity.

Q4. Which technical test is MOST appropriate for an AI Auditor to use when assessing whether an LLM application trained on customer data might reveal that specific customers were in the training dataset?

- A) Adversarial robustness testing using FGSM attack variants
- B) Membership inference attack testing
- C) Prompt injection testing for system prompt extraction
- D) Model fairness evaluation using AIF360

Answer: B Explanation: B is correct because membership inference testing specifically tests whether specific records can be identified as training data members — directly relevant to the question of whether customer records can be identified as being in the training dataset. A is wrong because FGSM (Fast

Gradient Sign Method) adversarial attacks test model robustness to adversarial input perturbations — relevant to accuracy under attack but not to training data privacy. C is wrong because prompt injection for system prompt extraction tests whether the system prompt can be revealed through adversarial prompting — relevant to confidentiality of system configuration, not to whether specific customer records are identifiable in training data. D is wrong because fairness evaluation measures demographic performance disparities — relevant to bias auditing but not to training data privacy.

Q5. Under EU AI Act (2024), which audit activity is required for high-risk AI applications under Article 72?

- A) One-time pre-deployment conformity assessment with no ongoing monitoring requirement
- B) Post-market monitoring — ongoing assessment of system performance and safety in production
- C) Annual re-certification by a notified body
- D) Quarterly reporting to the European Commission on model accuracy metrics

Answer: B **Explanation:** B is correct because EU AI Act Article 72 requires post-market monitoring for high-risk AI applications — a system for continuously collecting and analyzing data on the AI system's performance in production, including safety and fundamental rights implications. A is wrong because the EU AI Act specifically moves beyond one-time assessment to require ongoing monitoring — this is a key distinction from earlier regulatory frameworks. C is wrong because annual re-certification by a notified body is not a general EU AI Act requirement — conformity assessment frequency depends on system category and changes; ongoing monitoring replaces the concept of periodic snapshot assessments. D is wrong because quarterly reporting to the European Commission on specific metrics is not a EU AI Act requirement — the Act requires post-market monitoring plans and incident reporting, not periodic metric submissions to the Commission.

Q6. An AI Auditor reports to the same organizational executive who leads the AI product team responsible for the systems being audited. What is the PRIMARY independence risk this structure creates?

- A) The auditor may lack technical competency to evaluate AI systems
- B) Audit findings may be filtered or moderated before reaching governance stakeholders, compromising assurance credibility
- C) The auditor will have insufficient access to AI system documentation
- D) The audit cycle frequency may not meet regulatory requirements

Answer: B **Explanation:** B is correct because reporting to the operational executive creates structural dependence — the executive controls the auditor's access, scope, compensation, and career, creating incentives to moderate unfavorable findings before they reach the Board or Audit Committee. This is precisely the independence risk that structural independence requirements are designed to prevent. A is wrong because technical competency is a skills issue, not an independence issue — it is a concern regardless of reporting structure. C is wrong because access restrictions are a separate audit finding; insufficient structural independence typically means the auditor is given access to satisfy the form of an audit rather than being denied access. D is wrong because audit frequency is a scope decision, not a consequence of reporting structure independence.

Q7. An AI Auditor conducting a process walkthrough of model deployment governance observes that the documented approval workflow requires three sign-offs before production deployment, but operational teams routinely obtain only the business owner's sign-off and bypass the security and compliance reviews. What is the audit finding?

- A) The deployment process is compliant because the business owner's sign-off represents organizational approval
- B) A significant process compliance finding exists — the documented governance process is not being followed in practice
- C) The finding is informational only since no models have failed due to the abbreviated review process
- D) The auditor should recommend updating the policy to match actual practice rather than requiring compliance with the documented process

Answer: B **Explanation:** B is correct because process compliance auditing specifically tests whether the organization follows its own documented procedures — and a documented three-step approval process being routinely compressed to one step is a significant compliance finding, regardless of whether failures have occurred. A is wrong because the business owner's sign-off does not satisfy requirements for security and compliance reviews — the documented process requires all three, and the purpose of requiring multiple reviews is precisely that no single reviewer has all required competencies. C is wrong because the absence of observed failures does not indicate the process gap is acceptable — control failures often precede visible failures by a significant interval, and the risk exists whether or not a failure has yet materialized. D is wrong because recommending policy changes to accommodate non-compliant behavior is not an appropriate audit response — the finding is non-compliance, and the audit recommendation should address restoring compliance.

Q8. ISO/IEC 42001:2023 requires internal audit as a core element of the AI Management System. What is the PRIMARY purpose of the internal audit requirement?

- A) To produce documentation that satisfies external auditor requests during third-party certification audits
- B) To provide management with independent assurance that the AI Management System is implemented and effective
- C) To verify that AI models meet the performance thresholds documented in their governance artifacts
- D) To assess compliance with EU AI Act conformity assessment requirements

Answer: B **Explanation:** B is correct because ISO management system standards — including ISO/IEC 42001 — require internal audit to provide management with independent assurance that the management system is being implemented as designed and is achieving its objectives. A is wrong because while internal audit records support third-party certification audits, the ISO standard's requirement is not instrumentally defined by external audit needs — internal audit serves an organizational governance function. C is wrong because model performance verification is an element of what AI management system effectiveness encompasses, but it is narrower than the full purpose of internal audit, which covers all management

system elements. D is wrong because EU AI Act conformity assessment is a regulatory requirement separate from ISO 42001 — while the two overlap, internal audit under ISO 42001 is not defined by EU regulatory compliance objectives.

Q9. An AI Auditor finds that a deployed model's accuracy has degraded significantly from the threshold documented in its model card, but no governance review was triggered and no alert was issued. What does this finding PRIMARILY indicate?

- A) The model card documentation threshold was set too aggressively
- B) The model's post-deployment performance monitoring system failed to detect the degradation
- C) The model should be immediately decommissioned
- D) The finding requires external regulatory notification under EU AI Act

Answer: B **Explanation:** B is correct because the absence of an alert for significant performance degradation against a documented threshold indicates that the post-deployment monitoring system either was not configured to monitor the relevant metric, had thresholds set below the documented requirement, or failed to generate and route alerts correctly — a monitoring control failure. A is wrong because the finding that the model has degraded to below the documented threshold indicates the threshold was appropriate — the problem is that the degradation was not detected. C is wrong because immediate decommissioning may not be warranted; the appropriate response depends on the severity of degradation and the risk profile of the application — but the audit finding is the monitoring failure, not a decommissioning recommendation. D is wrong because EU AI Act notification requirements apply to serious incidents (malfunctions creating safety risks) — performance degradation below threshold triggers governance review, not necessarily regulatory notification.

Q10. Which description BEST characterizes the role of the AI Auditor in the NIST AI RMF 1.0 risk management cycle?

- A) The AI Auditor primarily operates in the MAP function — identifying and characterizing AI risks
- B) The AI Auditor operates across MAP, MEASURE, and MANAGE to coordinate risk management activities
- C) The AI Auditor provides independent verification that the MAP → MEASURE → MANAGE cycle was followed correctly and controls are effective
- D) The AI Auditor operates in MANAGE — implementing risk treatment controls identified by the risk assessment

Answer: C **Explanation:** C is correct because the Auditor's role in the NIST AI RMF cycle is independent verification — verifying that the risk management cycle was followed (MAP produced documented risk identification, MEASURE produced quantified risk levels, MANAGE produced implemented controls) and that the controls resulting from MANAGE are actually effective. This is a verification function, not an operational function within any single NIST AI RMF function. A is wrong because MAP is the AI Risk Analyst's primary function — identifying and characterizing risks. B is wrong because the Auditor does not coordinate or operate within the MAP/MEASURE/MANAGE cycle — they verify it independently. D is wrong because MANAGE (implementing risk treatment) is the Governance Engineer's and Security Architect's domain — not the Auditor's.

